Kriptográfia és biztonság 2.

Tökéletes biztonság

Modern vs. hagyományos kriptográfia

Emlékeztető: hagyományos kripto

- Inkább művészet, mint tudomány
- Ad-hoc konstrukciók
- Feltörve

Modern kripto alapelvei

1. precíz definíciók formalizálása
2. precíz feltevésekre építeni
3. szigorú biztonsági bizonyítások

Első alapelv: precíz definíciók

Precíz definíciók

- tervezés (mi a cél? ne post-facto)
- használat (megfelelő a titkosítás?)
- elemzés (összehasonlítás)
- intuíció nem elég

Biztonságos titkosítás „definiálása”

Egy titkosítás biztonságos, ha ???

Első alapelv: precíz definíciók

Biztonságos titkosítás „definiálása”

Egy titkosítás biztonságos, ha

Első alapelv: precíz definíciók

Biztonságos titkosítás „definiálása”

Egy titkosítás biztonságos, ha

1. semmilyen támadó nem tudja meg a kulcsot a titkos szövegből (kulcs nélkül)

Első alapelv: precíz definíciók

Biztonságos titkosítás „definiálása”

Egy titkosítás biztonságos, ha

1. semmilyen támadó nem tudja meg a kulcsot a titkos szövegből (kulcs nélkül)
2. semmilyen támadó nem tudja meg az üzenetet a titkos szövegből (csak 1 karaktert nem tud)

Első alapelv: precíz definíciók

Biztonságos titkosítás „definiálása”

Egy titkosítás biztonságos, ha

1. semmilyen támadó nem tudja meg a kulcsot a titkos szövegből (kulcs nélkül)
2. semmilyen támadó nem tudja meg az üzenetet a titkos szövegből (csak 1 karaktert nem tud)
3. semmilyen támadó nem tudja meg az üzenet egyik karakterét sem a titkos szövegnek (nagyságrend)

Első alapelv: precíz definíciók

Biztonságos titkosítás „definiálása”

Egy titkosítás biztonságos, ha

1. semmilyen támadó nem tudja meg a kulcsot a titkos szövegből (kulcs nélkül)
2. semmilyen támadó nem tudja meg az üzenetet a titkos szövegből (csak 1 karaktert nem tud)
3. semmilyen támadó nem tudja meg az üzenet egyik karakterét sem a titkos szövegnek (nagyságrend)
4. semmilyen támadó nem tudja meg az üzenetből semmi lényegeset a titkos szövegből (mi a lényeges?)

Első alapelv: precíz definíciók

Biztonságos titkosítás „definiálása”

Egy titkosítás biztonságos, ha

1. semmilyen támadó nem tudja meg a kulcsot a titkos szövegből (kulcs nélkül)
2. semmilyen támadó nem tudja meg az üzenetet a titkos szövegből (csak 1 karaktert nem tud)
3. semmilyen támadó nem tudja meg az üzenet egyik karakterét sem a titkos szövegnek (nagyságrend)
4. semmilyen támadó nem tudja meg az üzenetből semmi lényegeset a titkos szövegből (mi a lényeges?)
5. semmilyen támadó nem tudja meg az üzenet semmilyen függvényét a titkos szövegből

Első alapelv: precíz definíciók

Mi kell a definícióhoz

- mi a „törés”?
- az ellenség kapacitása?

Példa

Egy adott feladatra szánt kriptográfiai rendszer biztonságos, ha semmilyen, adott kapatásokkal rendelkező ellenfél nem tud végrehajtani egy adott törést.

Első alapelv: precíz definíciók

Matematika vs. valóság

- hardveres támadások
- emberi tényező

Jó biztonság definíció

- intuíciónak megfeleljen
- ekvivalencia bizonyítása
- példák
- sokat vizsgált

Második alapelv: precíz feltevések

Két változat

- feltétel nélküli biztonság
- számítási biztonság

Miért kell

- feltevések validálása
- megoldások összehasonlítása, ha lehetséges
- bizonyítások megkönnyítése

Harmadik alapelv: precíz biztonsági bizonyítások

Miért kell

- biztonság vs szoftver ellenőrzés
- működik $\not\Rightarrow$ nem törhető
- lehetséges károk (gyenge kriptorendszer vs hibás szoftver)

Redukciós megközelítés

Az X protokoll egy adott definíció szerint biztonságos, feltéve, hogy igaz az Y feltevés.

Titkosítási séma

Informálisan

Egy titkosítás megadásához szükséges

- három algoritmus: Gen, Enc, Dec
- az $\mathcal{M}$ üzenet-tér megadása

Paraméterek

- *kulcs-tér*: $\mathcal{K}$ lehetséges kulcsok halmaza ($k \in \mathcal{K}$)
- *üzenet-tér*: $\mathcal{M}$ lehetséges üzenetek halmaza ($m \in \mathcal{M}$)
- *titkos szöveg-tér*: $\mathcal{C}$ lehetséges titkos szövegek halmaz
- véges $\mathcal{K}$ kulcs-tér és $\mathcal{C}$ titkos szöveg-tér

Titkosítási séma

Paraméterek

- $\mathcal{K}, \mathcal{M}, \mathcal{C}$ feletti *valószínűségi eloszlások*
- $k \in \mathcal{K} : Pr(K = k)$ annak a valószínűsége, h a kulcs éppen k

Pl: $\mathcal{K}$: 128 hosszú bitsorozatok,
$k \in_R \mathcal{K} \Rightarrow Pr(K = k) = 1/2^{128}$

Titkosítási séma

Paraméterek

- $\mathcal{K}, \mathcal{M}, \mathcal{C}$ feletti *valószínűségi eloszlások*
- $k \in \mathcal{K} : Pr(K = k)$ annak a valószínűsége, h a kulcs éppen k

Pl: $\mathcal{K}$: 128 hosszú bitsorozatok,
$k \in_R \mathcal{K} \Rightarrow Pr(K = k) = 1/2^{128}$

- hasonló $\mathcal{M}, \mathcal{C}$-re

Pl: $|\mathcal{M}| = 2, Pr(\text{holnap támadás}) = 0.7, Pr(\text{nem támadunk}) = 0.3$

- $\mathcal{K}$ és $\mathcal{M}$ feletti eloszlások *függetlenek*
- $\mathcal{C}$ feletti eloszlást a fentiek definiálják
- *feltételes valószínűség*: $Pr(A|B) : A$ bekövetkezésének a valószínűségét, feltéve hogy a B esemény már bekövetkezett

Titkosítási séma

Definíció

*Egy **titkosítási séma** egy $\Pi = (Gen, Enc, Dec)$ hármas, amire:*

- Gen *a kulcsgenerálás, egy valószínűségi algoritmus, ami adott biztonsági paraméterre egy* $k \in_R \mathcal{K}$ *kulcsot ad vissza*
- Enc *a titkosítás, egy valószínűségi algoritmus, ami* $k \in \mathcal{K}$ *kulcs és* $m \in \mathcal{M}$ *üzenet esetén egy* $c \in \mathcal{C}$ *titkosszöveget ad vissza:* $c := Enc_k(m)$.
- Dec *a visszafejtés egy determinisztikus algoritmus, ami adott* k *kulcs és* $c \in \mathcal{C}$ *esetén* $\mathcal{M}$ *egy elemét adja vissza:* $Dec_k(c)$.

Biztonság definíciók

Intuíció

- üzenetek eloszlása ismert
- a titkos szöveg ismeretében ne lehessen semmit megtudni az üzenetről
- támadó számítási kapacitása: végtelen

Definíció

Egy titkosítási séma ***tökéletesen biztonságos*** $\mathcal{M}$ *felett, ha* $\forall \mathcal{M}$ *feletti eloszlásra,* $\forall m \in \mathcal{M}, \forall c \in \mathcal{C}$:

$$Pr(M = m) = Pr(M = m | C = c).$$

Biztonság definíciók

Ekvivalens megfogalmazás

- két (ismert) üzenet eltitkosítása között nem tehető különbség

Lemma (Tökéletes megkülönböztethetetlenség)

Egy titkosítási séma tökéletesen biztonságos $\mathcal{M}$ felett, ha $\forall \mathcal{M}$ feletti eloszlásra, $\forall m_1, m_2 \in \mathcal{M}, \forall c \in \mathcal{C}$:

$$Pr(C = c|M = m_1) = Pr(C = c|M = m_2).$$

Biztonság definíciók

Ekvivalens megfogalmazás

- megkülönböztethetlenségi kísérlet: játék a támadó és egy tesztelő között, aki a sikerességét méri

Lehallgatásos megkülönböztethetetlenség kísérlet $PrivK^{eav}_{\mathcal{A},\Pi}$

1. az $\mathcal{A}$ támadó kiad m_0, m_1 üzeneteket, amire $|m_0| = |m_1|$
2. $k \in_R \mathcal{K}, b \in_R \{0,1\}$ rejtve $\mathcal{A}$ elől, $c = Enc_k(m_b)$ ezt megkapja $\mathcal{A}$
3. $\mathcal{A}$ kiad $b' \in \{0,1\}$
4. $PrivK^{eav}_{\mathcal{A},\Pi} = 1$, ha $b = b'$, és 0 egyébként

Biztonság definíciók

Lehallgatásos megkülönböztethetetlenség kísérlet $PrivK^{eav}_{\mathcal{A},\Pi}$

1. az $\mathcal{A}$ támadó kiad m_0, m_1 üzeneteket, amire $|m_0| = |m_1|$
2. $k \in_R \mathcal{K}, b \in_R \{0,1\}$ rejtve $\mathcal{A}$ elől, $c = Enc_k(m_b)$ ezt megkapja $\mathcal{A}$
3. $\mathcal{A}$ kiad $b' \in \{0,1\}$
4. $PrivK^{eav}_{\mathcal{A},\Pi} = 1$, ha $b = b'$, és 0 egyébként

Definíció

Egy Π titkosítási séma ***tökéletesen biztonságos*** *$\mathcal{M}$ felett, ha $\forall \mathcal{A}$ támadóra,*

$$Pr(PrivK^{eav}_{\mathcal{A},\Pi} = 1) = \frac{1}{2}.$$

Lemma

A két definíció ekvivalens.

One-time pad

One-time pad titkosítás

Inicializálás $\mathcal{K} = \mathcal{M} = \{0,1\}^n$

Gen legyen $k \in_R \{0,1\}^n$ uniform véletlen

Enc adott $k \in \{0,1\}^n$ kulcs és $m \in \{0,1\}^n$ üzenet esetén $c = Enc_k(m) = k \oplus m$.

Dec adott k kulcs és $c \in \{0,1\}^n$ titkosszöveg esetén $Dec_k(c) = c \oplus k$.

Tétel

A one-time pad titkosítás tökéletesen biztonságos.

Tökéletes biztonság hátrányai

One-time pad tulajdonságok

- $|k| = |m| \Rightarrow$ kulcskezelési gondok
- "one-time"
- általános problémák tökéletes biztonságnál

Tétel

Legyen Π egy tökéletesen biztonságos titkosítási séma $\mathcal{M}$ felett és legyen $\mathcal{K}$ a Gen által meghatározott kulcstér. Ekkor $|\mathcal{K}| \geq |\mathcal{M}|$.

Ma is tanultam valamit

Összegzés

- Modern kripto 3 alapelve
- Több, ekvivalens biztonsági definíció
- One-time pad: $\exists$ tök. biztonságos titkosítás, de...